

Esercitazione: Scenario Ospedale Digitale

Sfeir Christian - Chiappini Mario

Marzo 2026

Introduzione e Componenti dell'Infrastruttura

Analisi dello scenario "ospedale digitale". I vincoli reali dell'infrastruttura includono la continuità del servizio, la safety dei pazienti, la presenza di sistemi legacy e le necessità di manutenzione remota. L'infrastruttura in analisi è composta dai seguenti asset:

- **EHR / cartelle cliniche (server + DB):** Cuore gestionale dei dati dei pazienti.
- **Wi-Fi ospiti/pazienti:** Rete pubblica per l'accesso a Internet.
- **Dispositivi medici IoT/OT.**
- **Prenotazioni (cloud):** Portale esterno per le visite.
- **VPN medici remoti:** Accesso per telemedicina e manutenzione.
- **PACS (Picture Archiving and Communication System):** Server per l'archiviazione delle immagini (RX, TAC, RMN).
- **LIS (Laboratory Information System):** Sistema per l'analisi dei campioni e refertazione.

Step 1: Asset Inventory

Asset	Tipo	Criticità	Dipendenze
EHR / Cartelle cliniche	Server + DB	Alta	LAN interna, Storage
Wi-Fi ospiti/pazienti	Access Point	Bassa	ISP
Dispositivi medici IoT	Endpoints	Estrema	Rete interna, Legacy
Prenotazioni	Cloud	Media	Internet, DB anagrafico
VPN medici remoti	Gateway	Alta	ISP, Firewall
PACS	Storage/App	Alta	DB centrale, Macchinari
LIS	Applicativo	Alta	DB centrale, Macchinari

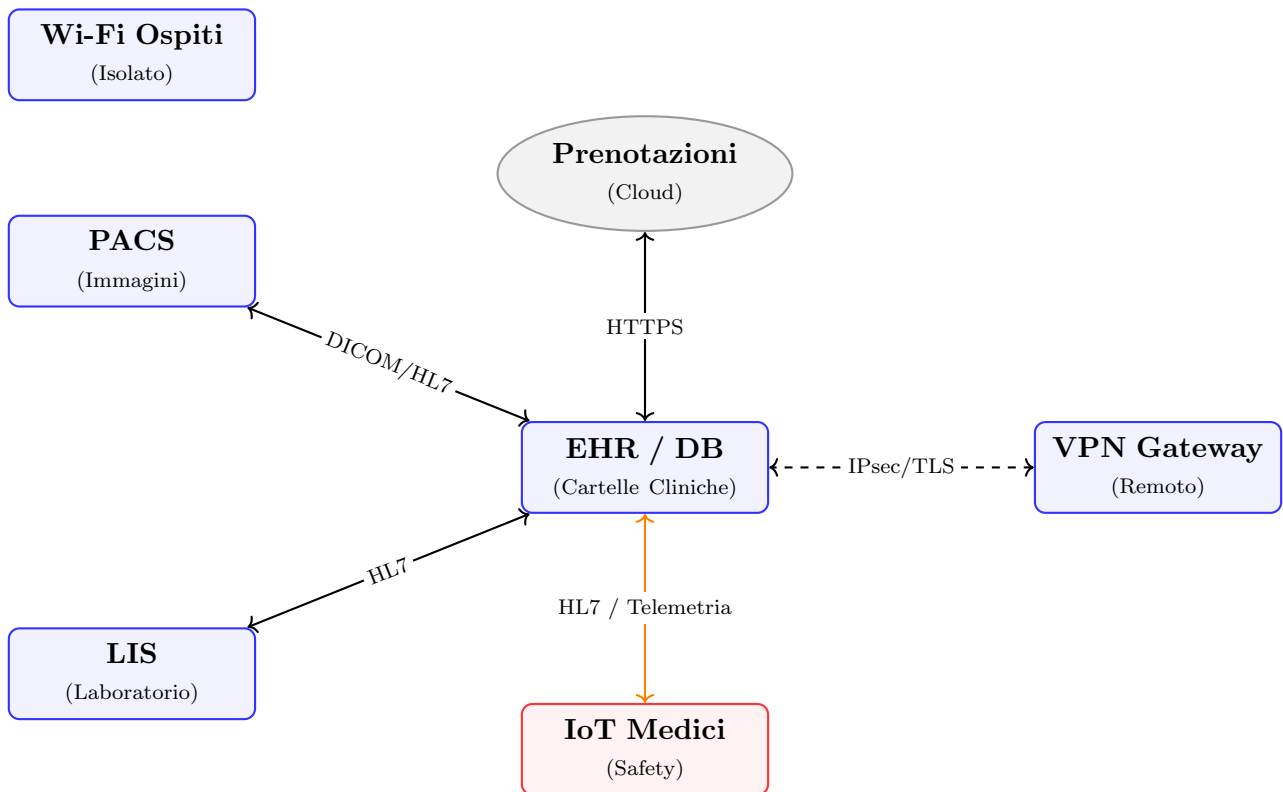
Step 2 & 3: Superficie Osservabile e Inferenza Attacco

Asset	Osservabile	Inferenza	Attacco
EHR / DB	Traffico elevato, query DB.	Consultazione continua dei dati.	Ransomware: blocco dati.
Wi-Fi ospiti/pazienti	MAC address eterogenei.	Dispositivi personali (BYOD).	Lateral Movement / MITM.
Dispositivi medici IoT	Traffico periodico, protocolli in chiaro.	Monitoraggio parametri vitali.	Data Tampering / DoS.
Prenotazioni	Chiamate API verso l'esterno.	Sincronizzazione agende cloud.	API Abuse / DoS.
VPN medici remoti	Traffico IPsec/TLS in entrata.	Accessi per telelavoro.	Credential Stuffing.
PACS	Picchi di traffico TCP pesanti.	Trasferimento immagini DICOM.	Esfiltrazione: furto dati.
LIS	Traffico dati HL7 verso il DB.	Refertazione analisi di laboratorio.	Esfiltrazione / Manipolazione.

Step 4: Grafo dell'infrastruttura Completa

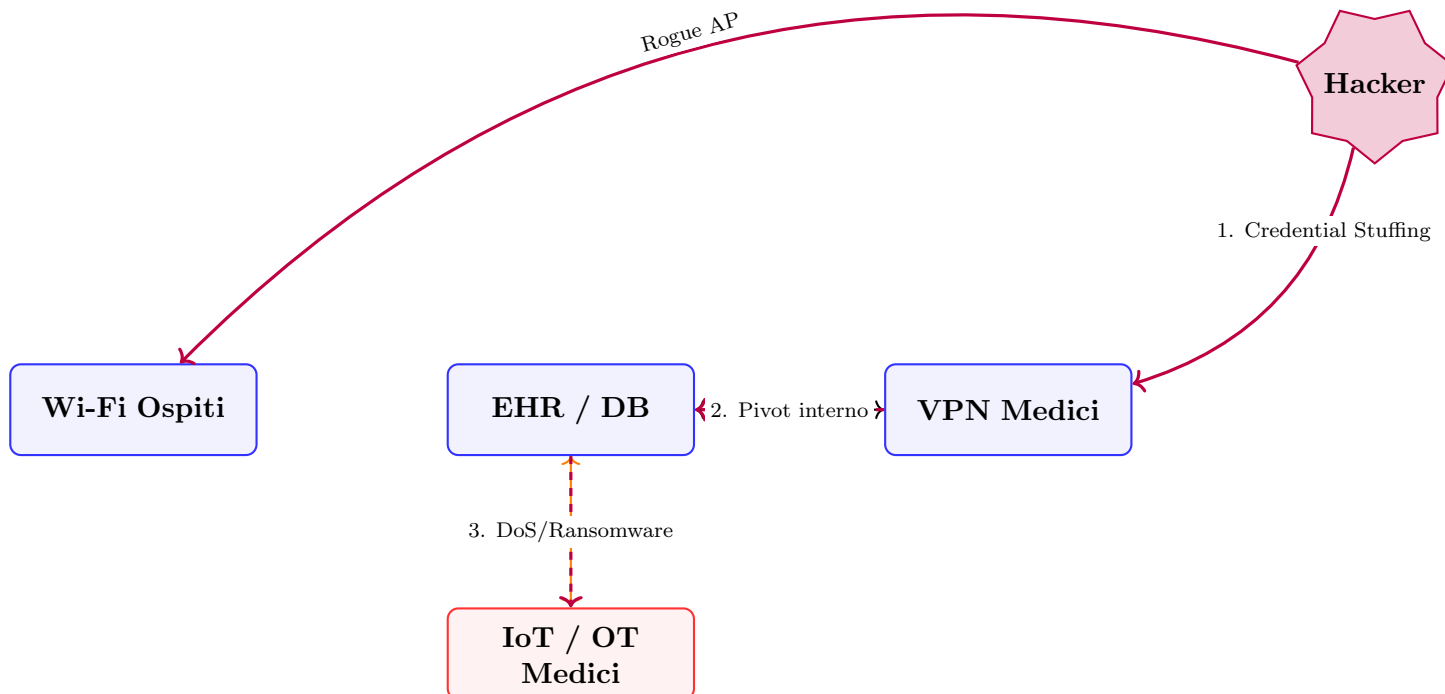
Baseline

Rappresentazione topologica ordinata delle comunicazioni tra gli asset.



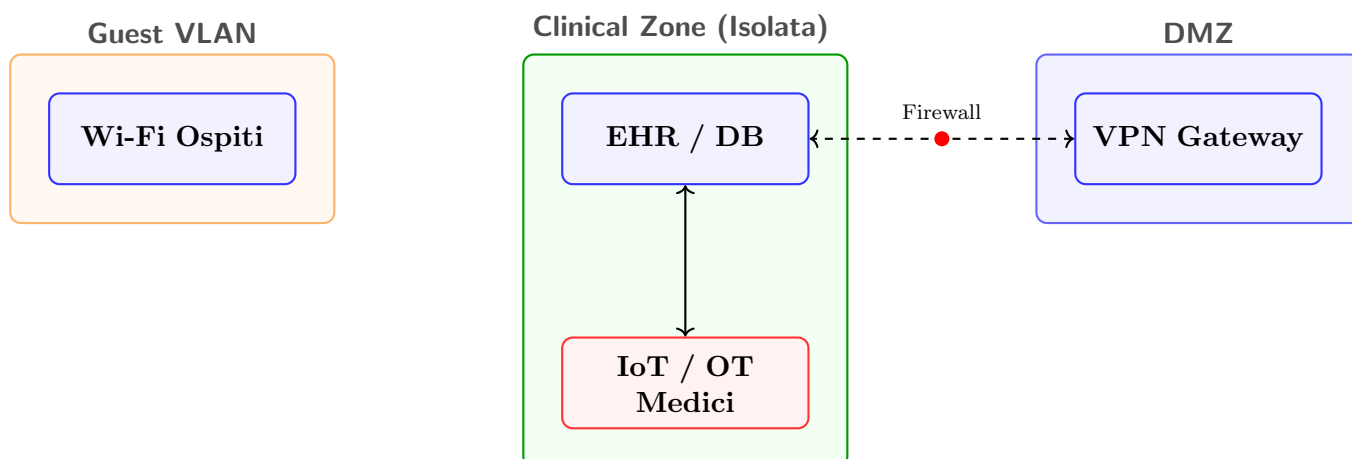
Variante 2: Kill Chain e Vettori di Attacco

Inclusione di un Threat Actor e dei potenziali percorsi di propagazione dell'attacco (Pivot).



Variante 3: Segmentazione di Rete (Mitigazione by Design)

Isolamento logico degli asset tramite zone (VLAN/DMZ) per impedire il movimento laterale.



Debrief

1. Asset più critico?

I dispositivi medici IoT/OT. La loro compromissione causa danni diretti ai pazienti violando il vincolo di *safety*.

2. Asset più osservabile?

Il Wi-Fi ospiti e le Prenotazioni Cloud, essendo esposti direttamente verso l'esterno.

3. Asset più pericoloso come pivot?

La VPN. Consente a un attaccante esterno di aggirare il perimetro di sicurezza e accedere ai sistemi centrali (EHR, PACS, LIS).

4. Controllo by design prioritario?

La **Network Segmentation**. Separare rigorosamente le reti IT (EHR, PACS, LIS), le reti IoMT (dispositivi medici) e le reti Guest per impedire movimenti laterali.

1 Laboratorio 2: From Model to Baseline

L'obiettivo è usare il modello del Laboratorio 1 per definire una baseline comportamentale. La normalità non è un punto singolo, ma un involucro operativo (Operating Envelope). La classificazione deve distinguere tra normalità, deviazione lieve, deviazione forte e comportamenti non classificabili (unknown).

1.1 Step 2: Definizione Baseline Qualitativa

Vengono identificate le relazioni attese e le relative configurazioni temporali e volumetriche per definire le deviazioni.

Relazione	Normale	Quando	Intensità	Note
VPN → EHR	Sì	Giorno / Notte	Media	Accesso remoto medici
EHR → DB	Sì	Sempre	Alta	Backend applicativo
IoT Medici → EHR	Sì	Sempre	Media/Bassa	Invio costante telemetria (Safety)
PACS → EHR	Sì	Giorno	Alta (picchi)	Trasferimento file pesanti (DICOM)
Guest Wi-Fi → EHR	No	Mai	Nulla	Deviazione topologica (Segmentazione)
EHR → Backup	Sì	Notte	Alta	Sincronizzazione pianificata
Device1 → DB	No	Mai	Nulla	Percorso non previsto (Pivot)

1.2 Step 3: Finestra Osservata

Dataset ricevuto contenente la telemetria di rete in una specifica finestra temporale:

Time	Source	Dest	Proto	Pkts	Status
08:10	VPN	EHR	TLS	145	ok
08:11	EHR	DB	TCP	240	ok
08:12	Device1	EHR	TLS	62	ok
08:13	Device2	EHR	TLS	59	ok
08:14	EHR	BookingCloud	HTTPS	95	ok
08:16	Guest WiFi	EHR	TCP	18	ok
08:17	Unknown Host	EHR	TCP	27	fail
08:18	VPN	EHR	TLS	310	retry
08:19	EHR	DB	TCP	520	ok
08:20	Device1	DB	TCP	44	ok
02:05	EHR	Backup	TCP	980	ok
02:07	Backup	EHR	TCP	155	ok
02:09	VPN	EHR	TLS	88	ok
02:10	EHR	Booking Cloud	HTTPS	140	ok
02:11	DB	Unknown Host	TCP	160	ok

1.3 Step 4 e 5: Valutazione Deviazioni e Classificazione

Analisi degli eventi anomali rispetto alla baseline costruita, fornendo motivazione e classificazione.

Evento	Compatibile	Score	Classificazione	Dato Utile (Giustificazione)
08:16 Guest → EHR	No	Forte	Attacco	<i>Log Firewall.</i> Violazione della segmentazione di rete. Deviazione topologica grave.
08:17 Unk → EHR	No	Medio	Attacco	<i>IP Sorgente/Porta.</i> Tentativo di accesso/scansione fallito dall'esterno.
08:18 VPN → EHR	No	Medio	Fault / Attacco	<i>Log autenticazione VPN.</i> Anomalia volumetrica e di stato (retry continui). Possibile Credential Stuffing o problemi di connessione del medico.
08:20 Device1 → DB	No	Forte	Attacco	<i>Traffico di Rete / Policy.</i> Dispositivo IoT aggira l'EHR. Chiaro indicatore di <i>Lateral Movement</i> o misconfigurazione post-infezione.
02:10 EHR → Booking	Parziale	Lieve	Unknown	<i>Log schedulazioni.</i> Possibile traffico automatizzato lecito, ma la classificazione iniziale corretta in assenza di prove è <i>Unknown</i> .
02:11 DB → Unk Host	No	Forte	Attacco	<i>Payload/Query DB.</i> Il DB non deve esporre traffico verso l'esterno. Rischio estremo di esfiltrazione dati / Regime Shift.

2 Debrief Finale

Le considerazioni seguenti fondono il debrief della topologia di rete (Lab 1) con la classificazione operativa e l'incertezza (Lab 2).

1. **Quale asset è più critico e quale deviazione è più grave?** L'asset più critico è rappresentato dai dispositivi IoT/OT medici, poiché impattano direttamente sulla *safety* umana. Tuttavia, la deviazione informatica più grave rilevata nella finestra è la connessione **02:11 DB → Unknown Host**. Essendo il DB l'asset centrale contenente dati sensibili (EHR), una connessione in uscita sconosciuta indica una probabile violazione dei dati (Data Exfiltration). Anche l'evento **08:16 Guest WiFi → EHR** è estremamente grave in quanto indica un fallimento totale del design di segmentazione logica (VLAN).
2. **Quale deviazione è più ambigua?** La connessione **08:18 VPN → EHR (TLS, retry)**. I *retry* aumentati potrebbero essere un medico in telelavoro con problemi di connessione (guasto/fault) o una password scaduta, ma potrebbero ugualmente indicare un attacco di forza bruta (*credential stuffing*). Serve più contesto (Log Auth).
3. **In quali casi la risposta corretta è unknown?** L'evento **02:10 EHR → Booking Cloud (HTTPS)**. L'orario notturno desta sospetti, ma un'infrastruttura moderna cloud spesso esegue *batch jobs* di sincronizzazione notturna. Non etichettiamo ciecamente come "attacco", ma lasciamo lo stato in *unknown* finché non verifichiamo la baseline temporale sui processi pianificati.
4. **Quale controllo *by design* preverrebbe i falsi negativi e isolerebbe gli impatti?** La **Network Segmentation**. Separare rigorosamente le reti IT (EHR, DB), IOMT (Dispositivi medici) e Guest. Se la segmentazione fosse implementata in modo robusto tramite Firewall fisici/logici (e non solo logica applicativa), eventi come "Guest WiFi → EHR" o "Device1 → DB" verrebbero scartati (Drop) direttamente all'edge, riducendo lo sforzo di anomaly detection.

"Detection non significa indovinare attacchi. Significa ridurre l'incertezza fino a una decisione difendibile."